

QA Report: Partner Onboarding & KYB Service

Report ID: QA-PEG-001 | **Date:** 2026-04-09 | **Sprint:** Sprint 3 **Service:** Ubn-User-Management | **Environment:** Development (dev-api.onecluster.co)

Executive Summary

The Partner Onboarding & KYB service handles partner registration, email verification, KYB document upload, and lifecycle state management. This report covers QA testing of the onboarding flow on the development environment.

Scope

- POST /api/Auth/register — Partner registration with NDPR consent
- POST /api/Auth/completeSignup — Password creation via token
- POST /api/Auth/login — Authentication and JWT issuance
- POST /api/Auth/forgotPassword — Password reset request
- POST /api/Auth/resetPassword — Password reset execution
- POST /api/Auth/sendOtp — Email verification code
- POST /api/Auth/verifyEmailCode — Email verification
- POST /api/Auth/ChangePassword — Password change
- KYB document upload and review workflow
- State machine: PENDING_EMAIL_VERIF → EMAIL_VERIFIED → KYB_SUBMITTED → KYB_APPROVED → ACTIVE

Changes This Sprint (Mar 31 — Apr 9)

- 117 commits to Ubn-User-Management
- Removed AES encryption middleware (security simplification)
- Removed CryptoEndpoints (deprecated)
- Added KYB auto-review service improvements
- New migration: RenameAdminPermissionToOwner
- New migration: AddKycCompleted flag
- Fixed PEG-393, PEG-394, PEG-395 bugs
- Enabled Swagger in staging environment
- Stripped secrets from appsettings.json (PEG-351)
- Fixed user role guard (security fix)
- 15+ merged PRs including progress tracker, AML flags, RBAC roles

Test Results

Registration Flow

Test ID	Test Case	Expected	Actual	Status	Notes
QA-ONB-001	Register with valid data	201 Created	201 + partnerId returned	PASS	Idempotency key works correctly
QA-ONB-002	Register with empty body	422 Validation error	422 with field-level errors (companyName, institutionType, termsConsent required)	PASS	Proper RFC 7807 format
QA-ONB-	Register with ndprConsent=false	422 NDPR_CONSENT_REQUIRED	Not tested — needs live environment	NOT RUN	Backend code confirms hard

003					gate
QA-ONB-004	Duplicate email registration	409 Conflict	Not tested	NOT RUN	Code review confirms idempotency check
QA-ONB-005	Register with free email (Gmail)	422 FREE_EMAIL_REJECTED	Not tested	NOT RUN	Code confirms rejection logic

Authentication Flow

Test ID	Test Case	Expected	Actual	Status	Notes
QA-ONB-006	Login with valid credentials	200 + JWT	200 with isSuccess:true, accessToken, refreshToken	PASS	JWT contains partnerId, organizationId claims
QA-ONB-007	Login with invalid credentials	401	200 with isSuccess:false, responseCode:"999"	FAIL	Returns HTTP 200 instead of 401 — see ISSUE PEG-379
QA-ONB-008	Forgot password (nonexistent email)	200 generic response	200 "If this email is registered, a reset link has been sent"	PASS	No user enumeration — secure
QA-ONB-009	sendOtp with empty body	400/422	429 Rate Limited	BLOCKED	Aggressive rate limiting — see ISSUE PEG-388
QA-ONB-010	Change password (valid)	200	Not tested — requires auth session	NOT RUN	

KYB Document Flow

Test ID	Test Case	Expected	Actual	Status	Notes
QA-ONB-011	Upload KYB documents	200	Verified in code: ICAP scan → AES-256 encryption → blob storage	CODE REVIEW PASS	ICAP stub active (ICAP__Enabled=false)
QA-ONB-012	KYB state transition on approval	State → KYB_APPROVED + sandbox key issued	Verified in AdminKybService: WORM audit → state change → key provisioned atomically	CODE REVIEW PASS	
QA-ONB-013	File type validation	PNG, JPG, PDF only, max 5MB	FileUploadService validates binary signatures (PDF 0x25504446, PNG 0x89504E47)	CODE REVIEW PASS	Deep binary inspection, not just extension
QA-ONB-014	PII masking in logs	BVN, NIN, email masked as ***	PiiScrubberDeconstructingPolicy active on 20+ field names	CODE REVIEW PASS	

Issues Found

ID	Severity	Issue	Status
PEG-379	Medium	Login returns HTTP 200 for failed auth — should return 401	OPEN
PEG-388	Low	sendOtp aggressively rate-limited (429 on first call)	OPEN
PEG-382	Medium	/api/Profile/GetAllRoles returns 404	OPEN

Recommendations

1. Fix login endpoint to return 401 for invalid credentials (REST convention)
2. Review sendOtp rate limiting — may be Cloudflare WAF, not application-level
3. Verify GetAllRoles endpoint exists or update Admin Portal to use correct path